

Security Assessment Report

Generated: 2026-05-05 10:07

Report ID: 8894200d

Executive Security Report

Executive Summary

Total vulnerabilities: 3

Highrisk issues: 0 highseverity findings, but the code contains unsafe subprocess usage that could allow command execution or abuse of local tooling, impacting system integrity and availability

Overall risk level: Medium

Technical Details

Finding 1 Unsafe subprocess invocation

Severity: Low

AI Explanation: The application calls `subprocess.run()` to launch `bandit` using a path supplied by the request. Even though `shell=False` is used, this still creates risk if untrusted input reaches the command arguments or if the invoked tool behaves unexpectedly on attackercontrolled paths.

Fix Suggestion: Validate and restrict the requested path to an allowlist of approved directories, and avoid passing usercontrolled paths directly into subprocess calls.

Finding 2 Partial executable path for bandit

Severity: Low

AI Explanation: The code invokes `bandit` without an absolute path, which can be abused if the environment is compromised or `PATH` is manipulated.

Fix Suggestion: Use a fully qualified executable path or a controlled execution environment with a fixed `PATH`.

Finding 3 Subprocess module security concern

Severity: Low

AI Explanation: Importing and using `subprocess` is not inherently bad, but it often becomes a security issue when combined with untrusted input and external command execution.

Fix Suggestion: Replace subprocessbased execution with a direct library/API call where

possible, or add strict input validation and execution controls.

Tool outcomes (Bandit, Sonar, Safety, ZAP):

Bandit: Succeeded — found 3 lowseverity issues in server.py

Sonar: Succeeded — no issues reported

Safety: Failed — no requirements.txt found in project

ZAP: Not run — no URL target was provided

Tool Failures

Safety scan could not run because the project does not contain a requirements.txt file.